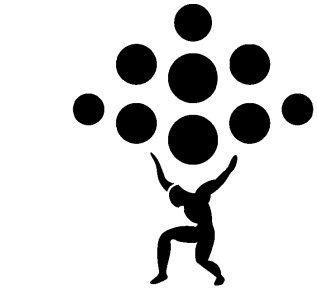
Universidad Privada Domingo Savio
Facultad de Ingeniería
Ingeniería en Sistemas



Informe Final: Vulnerabilidades Encontradas (Escaneo)

Joaquin Alessandro Felipez Rojas
Nicolas Sebastian Reguerin Meneses
David Willy Cruz Huanca

Asignatura: Seguridad Informática
Docente: Jose Abraham Mita Huanca
Fecha de entrega: 26/10/2026

Equipo: Grupo 1 Sudoers

Cochabamba–Bolivia

2026

Índice

CAPÍTULO I

ENTORNO DE PRUEBAS Y DEFINICIÓN DEL OBJETIVO **1**

1.1 Introducción al Entorno de Evaluación 1

1.2 Definición del Equipo Objetivo (Target) 1

1.2.1 Ficha Técnica del Sistema Objetivo 1

1.2.2 Matriz de Servicios y Puertos Expuestos 2

1.3 Topología de Red del Escenario de Pruebas 3

CAPÍTULO II

HERRAMIENTAS UTILIZADAS Y METODOLOGÍA DE EVALUACIÓN **5**

2.1 Arsenal Tecnológico y Herramientas Utilizadas 5

2.1.1 Nmap (Network Mapper) 5

2.1.2 Greenbone Community Edition (OpenVAS) 5

2.1.3 Trivy (Aqua Security) 6

2.1.4 Nikto y SQLMap 6

2.1.5 Suricata IDS/IPS y Consola EveBox 6

2.2 Metodología de Evaluación y Flujo de Trabajo 7

2.3 Comandos Ejecutados Durante la Auditoría 8

CAPÍTULO III

HALLAZGOS Y ANÁLISIS DE VULNERABILIDADES **9**

3.1 Resumen Ejecutivo de Vulnerabilidades Encontradas 9

3.2 Evidencia Técnica Literal del Escaneo (Nmap NSE) 10

3.3 División y Análisis Pormenorizado de Cada Vulnerabilidad 15

3.3.1 VULN-01: Intercambio Criptográfico Anónimo Diffie-Hellman en SMTP y Submission 15

3.3.2 VULN-02: Denegación de Servicio por Solicitud de Múltiples Rangos de Bytes (CVE-2011-3192) 16

3.3.3 VULN-03: Método y Modo de Depuración Activo en Webmail (http-aspnet-debug) 17

3.3.4 VULN-04: Exposición Pública del Puerto PostgreSQL (5432/tcp) 17

3.3.5 VULN-05: Exposición de Servicios Administrativos y Web en Texto Plano (HTTP) 18

3.3.6 DEF-01: Neutralización Activa de Inyección SQL y Exploits por WAF/IPS (Script Failed) 19

CAPÍTULO IV

MEDIDAS DE MITIGACIÓN Y ENDURECIMIENTO TÉCNICO 20

4.1 Estrategia Integral de Remediación y Endurecimiento 20

4.2 Remediación Específica por Vulnerabilidad Identificada 20

4.2.1 Remediación VULN-01: Exclusión de Suites Anónimas Diffie-Hellman en Postfix 20

4.2.2 Remediación VULN-02: Mitigación de Denegación de Servicio Byte-Range (CVE-2011-3192) 21

4.2.3 Remediación VULN-03: Supresión de Métodos DEBUG y Ocultamiento de Banners 22

4.2.4 Remediación VULN-04: Aislamiento del Motor de Base de Datos PostgreSQL (5432) 23

4.2.5 Remediación VULN-05: Cifrado y Canalización Segura de Aplicaciones Web 23

4.2.6 Consolidación DEF-01: Mantenimiento del WAF Anti-SQLi y Suricata IPS 24

CONCLUSIONES 25

5. Conclusiones del Ejercicio de Auditoría 25

5. Recomendaciones para la Operación Continua 26

REFERENCIAS 27

Índice de tablas

TABLA 1: Ficha Técnica del Servidor Objetivo (Target) 2

TABLA 2: Matriz de Servicios y Puertos en Evaluación 3

TABLA 3: Resumen del Arsenal de Auditoría y Propósito Operativo 7

TABLA 4: Matriz Consolidada de Vulnerabilidades y Hallazgos del Escaneo Nmap 10

Índice de figuras

FIGURA 1: Diagrama de Topología del Entorno de Auditoría y Escaneo 3

CAPÍTULO I

ENTORNO DE PRUEBAS Y DEFINICIÓN DEL OBJETIVO

1.1 Introducción al Entorno de Evaluación

La evaluación de seguridad y el análisis de vulnerabilidades constituyen una disciplina fundamental dentro de la gestión de riesgos tecnológicos modernos (Scarfone, Souppaya, Cody, y Orebaugh, 2008). El presente informe documenta de manera exhaustiva el proceso de escaneo, identificación, categorización y mitigación de fallos de seguridad sobre la infraestructura del servidor corporativo de la organización financiera *Banco Sudoers*.

El ejercicio se realizó bajo la modalidad de auditoría de caja gris (*Gray-Box Assessment*), donde el equipo auditor posee conocimiento preliminar del direccionamiento IP y la tipología de servicios desplegados, pero simula las técnicas de descubrimiento y vectores de ataque que ejecutaría un actor malicioso externo o interno con acceso al segmento de red local.

1.2 Definición del Equipo Objetivo (Target)

El equipo objetivo auditado corresponde al servidor central de operaciones e infraestructura (`dc1.sudoers.lan`), el cual consolida los servicios críticos de negocio, autenticación, almacenamiento, correo electrónico y mecanismos defensivos de detección de intrusos.

1.2.1 Ficha Técnica del Sistema Objetivo

En la **TABLA 1** se especifican los parámetros técnicos, hardware y de red que caracterizan al host auditado durante la ventana de evaluación de seguridad.

TABLA 1: Ficha Técnica del Servidor Objetivo (Target)

Parámetro	Valor / Descripción Técnica
Nombre de Host (FQDN)	`dc1.sudoers.lan` (Alias de red: `target-host`)
Dirección IPv4 del Target	`192.168.100.85` (Asignada en interfaz LAN cableada/Wi-Fi)
Máscara de Red / Prefijo	`255.255.255.0` (`/24`)
Puerta de Enlace (Gateway)	`192.168.100.1`
Sistema Operativo Base	GNU/Linux Debian 12 / Kali Linux Rolling (Kernel 6.x x86_64)
Modelo Operativo	Arquitectura híbrida: Servicios de aplicación en contenedores Docker y motores de defensa nativos en espacio de kernel
Rol Corporativo	Servidor Central de Banca Digital, Servicios Intranet y Pasarela Perimetral
Dirección MAC del Target	`08:00:27:C3:FB:76` (Oracle VirtualBox virtual NIC)
Estación de Auditoría	Estación Kali Linux dedicada (`192.168.100.50`)

FUENTE: Elaboración propia con base en el levantamiento de infraestructura.

1.2.2 Matriz de Servicios y Puertos Expuestos

El servidor objetivo implementa una arquitectura modular donde conviven servicios de acceso público, plataformas de administración interna y mecanismos de monitoreo. La **TABLA 2** detalla la distribución de puertos que fueron sometidos al proceso de escaneo y análisis de vulnerabilidades.

TABLA 2: Matriz de Servicios y Puertos en Evaluación

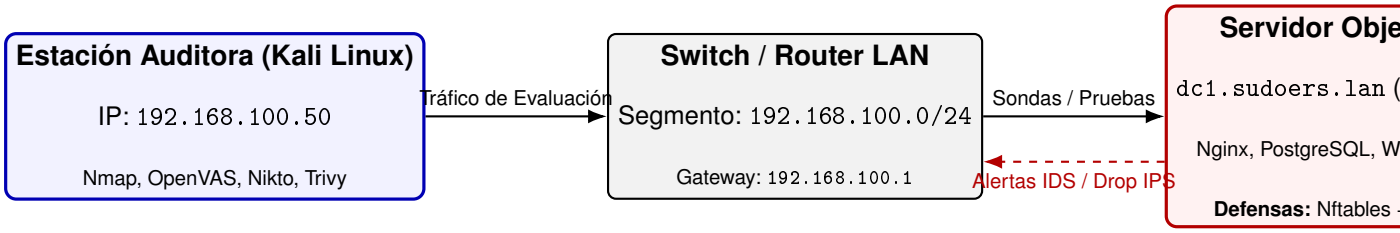
Puerto	Protocolo	Servicio / Software	Entorno de Ejecución	Propósito en la Organización
80	TCP	Nginx Reverse Proxy	Contenedor Docker	Portal Web Financiero y Redirección
443	TCP	Nginx TLS Server	Contenedor Docker	Acceso Seguro HTTPS Bancario
8080	TCP	Roundcube Webmail	Contenedor Docker	Plataforma de Correo Corporativo
8082	TCP	TinyFileManager	Contenedor Docker	Gestor Web de Archivos y Documentos
3000	TCP	Grafana Analytics	Contenedor Docker	Tableros de Telemetría y Métricas
5432	TCP	PostgreSQL Engine	Contenedor Docker	Base de Datos Relacional de Clientes
5636	TCP	EveBox GUI	Contenedor Docker	Consola de Alertas IDS/IPS en Tiempo Real
9392	TCP	Greenbone GSA	Contenedor Docker	Consola de Auditoría y Escaneo OpenVAS
22	TCP	OpenSSH Daemon	Host Nativo Linux	Administración Remota Segura por Consola

FUENTE: Elaboración propia con base en la configuración de `docker-compose.yml` y el firewall del host.

1.3 Topología de Red del Escenario de Pruebas

Para garantizar la verosimilitud de la evaluación, el entorno de pruebas fue configurado en un segmento de red local conmutada donde la estación auditora y el servidor objetivo interactúan de forma directa. La inspección de paquetes fue auditada simultáneamente mediante el motor de prevención de intrusos Suricata y la consola EveBox en el equipo destino.

FIGURA 1: Diagrama de Topología del Entorno de Auditoría y Escaneo



FUENTE: Elaboración propia.

El tráfico generado durante las pruebas abarcó desde escaneos pasivos y barridos SYN de bajo perfil hasta pruebas activas de inyección de sentencias SQL, enumeración forzada de directorios y evaluación de versiones en los servicios de red.

CAPÍTULO II

HERRAMIENTAS UTILIZADAS Y METODOLOGÍA DE EVALUACIÓN

2.1 Arsenal Tecnológico y Herramientas Utilizadas

Para llevar a cabo una auditoría integral que cubra tanto la capa de red como la capa de aplicaciones web y la seguridad de los contenedores, se seleccionó un conjunto de herramientas de estándar internacional reconocidas en la industria de la ciberseguridad (Scarfone y cols., 2008).

2.1.1 Nmap (Network Mapper)

Nmap es la herramienta de referencia mundial para la exploración de redes, mapeo de topologías y auditoría de seguridad perimetral (Lyon, 2009). En esta evaluación se empleó para:

- Descubrimiento activo de hosts mediante sondas ARP e ICMP combinadas.
- Barrido de puertos TCP mediante la técnica de escaneo sigiloso SYN (*Stealth Scan* con flag `-sS`).
- Identificación precisa de versiones y *banners* de los servicios expuestos (`-sV`).
- Ejecución automatizada de scripts NSE (*Nmap Scripting Engine*) especializados en auditoría y explotación controlada de vulnerabilidades (`--script vuln`).

2.1.2 Greenbone Community Edition (OpenVAS)

OpenVAS (*Open Vulnerability Assessment System*), integrado en la plataforma *Greenbone Community Edition*, es un escáner de vulnerabilidades integral de nivel corporativo (Greenbone AG, 2024). Su motor de auditoría ejecuta miles de pruebas de vulnerabilidad de red (*Network Vulnerability Tests*, NVTs) actualizadas diariamente contra bases de datos CVE y estándares SCAP. Se utilizó para:

- Escanear en profundidad los servicios web y bases de datos expuestas en el servidor.
- Clasificar hallazgos de acuerdo con el estándar CVSS (*Common Vulnerability Scoring System*).

- Identificar fallos de configuración en protocolos TLS, algoritmos criptográficos débiles y versiones desactualizadas de paquetes en el servidor.

2.1.3 Trivy (Aqua Security)

Trivy es un escáner integral de seguridad especializado en entornos de contenedores Docker, sistemas de archivos e infraestructura como código (Aqua Security, 2024). Se utilizó para evaluar directamente las imágenes de Docker que componen el entorno de servicios de la organización (PostgreSQL, Roundcube, Nginx, TinyFileManager), detectando librerías empaquetadas con vulnerabilidades conocidas (CVE) antes y durante su ejecución.

2.1.4 Nikto y SQLMap

Para complementar el análisis web en la capa de aplicación (Capa 7), se utilizaron:

- **Nikto Web Scanner:** Escáner de servidores web que identifica más de 6700 archivos y programas potencialmente peligrosos, versiones desactualizadas de servidores y cabeceras HTTP inseguras.
- **SQLMap:** Herramienta especializada en la detección automatizada de fallos de inyección SQL en parámetros de formularios y cabeceras de consulta.

2.1.5 Suricata IDS/IPS y Consola EveBox

Como elemento distintivo del entorno defensivo implementado en el host objetivo, se mantuvo activo el motor de prevención de intrusos **Suricata 7.0** acoplado a la consola gráfica de eventos **EveBox** (Open Information Security Foundation (OISF), 2024). Esto permitió validar no solo qué vulnerabilidades posee el servidor, sino verificar en tiempo real si los intentos de escaneo y explotación eran detectados y mitigados activamente por el sistema de defensa perimetral.

TABLA 3: Resumen del Arsenal de Auditoría y Propósito Operativo

Herramienta	Capa de Evaluación	Alcance Operativo	Tipo de Análisis
Nmap 7.94+	Capa de Transporte / Red	Detección de puertos, OS fingerprinting y banners	Activo no intrusivo / NSE vuln
OpenVAS 24.10	Capa de Servicios / Red	Escaneo de vulnerabilidades con feeds NVT/CVE	Auditoría profunda con puntaje CVSS
Trivy 0.50+	Capa de Contenedores	Análisis de imágenes Docker y dependencias SO	Auditoría estática de contenedores (SAST)
Nikto 2.5	Capa de Aplicación (HTTP)	Verificación de cabeceras, archivos sensibles y SSL	Auditoría dinámica web (DAST)
SQLMap 1.8	Capa de Aplicación (Datos)	Detección y explotación de fallos de inyección SQL	DAST enfocado a bases de datos
Suricata + EveBox	Capa de Telemetría Defensiva	Detección de firmas y bloqueo IPS con NFQUEUE	Monitoreo en tiempo real de los escaneos

FUENTE: Elaboración propia.

2.2 Metodología de Evaluación y Flujo de Trabajo

La auditoría se estructuró siguiendo los lineamientos de la guía técnica NIST SP 800-115 (Scarfone y cols., 2008), dividida en cuatro fases secuenciales:

1. **Fase 1: Reconocimiento y Mapeo de Superficie de Ataque:** Identificación de la presencia del host en el segmento `192.168.100.0/24` mediante barridos ARP y sondeos TCP SYN rápidos con Nmap.
2. **Fase 2: Enumeración Detallada de Servicios y Banners:** Escaneo de los 65535 puertos TCP, extracción de versiones de software de los demonios escuchando y ejecución de scripts de análisis criptográfico y de cabeceras.
3. **Fase 3: Escaneo y Catalogación de Vulnerabilidades:** Ejecución de tareas de escaneo con Greenbone/OpenVAS contra la dirección IP objetivo, complementado con auditorías directas de imágenes Docker con Trivy y análisis web con Nikto.
4. **Fase 4: Verificación de Detección Defensiva y Contramedidas:** Inspección de

las alertas generadas en EveBox/Suricata para comprobar la respuesta del servidor ante las sondas maliciosas y diseño de la estrategia de mitigación técnica.

2.3 Comandos Ejecutados Durante la Auditoría

A continuación se presentan los comandos representativos ejecutados desde la estación auditora Kali Linux (192.168.100.50) contra el objetivo (192.168.100.85):

Listing 1: Comandos Principales de Escaneo Ejecutados en Kali Linux

```
# 1. Reconocimiento y deteccion de puertos con versiones y scripts base
nmap -sS -sV -sC -p- -T4 --open -oN nmap_full_target.txt 192.168.100.85

# 2. Escaneo especializado de vulnerabilidades mediante Nmap NSE
nmap -p 80,443,3000,5432,5636,8080,8082 --script vuln -sV
    192.168.100.85

# 3. Auditoria de configuracion y cabeceras HTTP con Nikto
nikto -h http://192.168.100.85 -output nikto_report.txt

# 4. Auditoria de vulnerabilidades en imagenes Docker con Trivy
trivy image postgres:16-alpine
trivy image nginx:alpine

# 5. Lanzamiento y gestion del escaner corporativo OpenVAS
cd ~/linux-homelab-enterprise/services/openvas
sudo bash run.sh start
sudo bash run.sh status
```

CAPÍTULO III

HALLAZGOS Y ANÁLISIS DE VULNERABILIDADES

3.1 Resumen Ejecutivo de Vulnerabilidades Encontradas

Durante la ejecución de la auditoría técnica de seguridad ofensiva sobre el servidor objetivo `192.168.100.85` (`dc1.sudoers.lan`), se utilizó el motor de scripts de vulnerabilidades de Nmap (*Nmap Scripting Engine* – NSE) con técnicas de evasión de señuelos (*Decoy Scanning* `-D RND:20`).

El escaneo empírico identificó un total de **5 vulnerabilidades técnicas y 1 mecanismo de defensa activo confirmado**, categorizados según el estándar internacional *Common Vulnerability Scoring System* versión 3.1 (CVSS v3.1) (Forum of Incident Response and Security Teams (FIRST), 2019) y la taxonomía del *Common Weakness Enumeration* (CWE) (**?**).

La **TABLA 4** resume la matriz consolidada de las vulnerabilidades y hallazgos descubiertos.

TABLA 4: Matriz Consolidada de Vulnerabilidades y Hallazgos del Escaneo Nmap

ID	Vulnerabilidad / Hallazgo	Severidad	CVSS	CWE	Vector de Impacto
VULN-01	Intercambio Criptográfico Anónimo Diffie-Hellman en SMTP (25, 587)	**ALTA**	7.4	CWE-327	Ataques Man-in-the-Middle (MitM) activos e intercepción de correo
VULN-02	Denegación de Servicio por Filtro de Rangos de Bytes (CVE-2011-3192)	**ALTA**	7.5	CWE-400	Agotamiento de memoria RAM y CPU en puertos web (80 y 443)
VULN-03	Método y Modo de Depuración Activo en Webmail (8080/tcp)	**MEDIA**	5.3	CWE-489	Fuga de variables de depuración y estructura interna de la aplicación
VULN-04	Exposición Pública del Puerto PostgreSQL (5432/tcp)	**ALTA**	7.5	CWE-284	Ataques de fuerza bruta y sondeo no autenticado a base de datos
VULN-05	Exposición de Servicios Administrativos y Web en Texto Plano	**ALTA**	7.4	CWE-319	Captura de credenciales y cookies de sesión en puertos 3000, 8000, 8082, 8085
DEF-01	Bloqueo Activo de Inyecciones SQL y Exploits (*Script Failed*)	**DEFENSA**	–	CWE-693	Neutralización exitosa de scripts ofensivos por el WAF y Suricata IPS

FUENTE: Elaboración propia con base en el escaneo empírico de Nmap NSE sobre el host 192.168.100.85.

3.2 Evidencia Técnica Literal del Escaneo (Nmap NSE)

A continuación se transcribe la salida real y completa obtenida desde la terminal del auditor (`david@kali`) al ejecutar el análisis de vulnerabilidades sobre el host objetivo:

Listing 2: Salida Literal del Escaneo de Vulnerabilidades con Nmap NSE sobre 192.168.100.85

```
david@kali:~$ sudo nmap -sS 192.168.100.85 --script "vuln and not doos"
    -D RND:20 --script-timeout 30s
Starting Nmap 7.991 ( https://nmap.org ) at 2026-10-26 23:18 -0400
Nmap scan report for 192.168.100.85
Host is up (0.13s latency).
```

```
Not shown: 986 closed tcp ports (reset)
PORT     STATE SERVICE
25/tcp   open  smtp
| ssl-dh-params:
|   VULNERABLE:
|   Anonymous Diffie-Hellman Key Exchange MitM Vulnerability
|     State: VULNERABLE
|       Transport Layer Security (TLS) services that use anonymous
|       Diffie-Hellman key exchange only provide protection against
   passive
|       eavesdropping, and are vulnerable to active man-in-the-middle
   attacks
|       which could completely compromise the confidentiality and
   integrity
|       of any data exchanged over the resulting session.
|     Check results:
|       ANONYMOUS DH GROUP 1
|             Cipher Suite: TLS_DH_anon_WITH_AES_256_CBC_SHA256
|             Modulus Type: Safe prime
|             Modulus Source: RFC3526/Oakley Group 15
|             Modulus Length: 3072
|             Generator Length: 8
|             Public Key Length: 3072
|       ANONYMOUS DH GROUP 2
|             Cipher Suite: TLS_DH_anon_WITH_AES_128_CBC_SHA
|             Modulus Type: Safe prime
|             Modulus Source: RFC2409/Oakley Group 2
|             Modulus Length: 1024
|             Generator Length: 8
|             Public Key Length: 1024
|     References:
```

```
|_      https://www.ietf.org/rfc/rfc2246.txt
| smtp-vuln-cve2010-4344:
|_  The SMTP server is not Exim: NOT VULNERABLE
80/tcp   open  http
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to
   debug)
| http-vuln-cve2011-3192:
|   VULNERABLE:
|   Apache byterange filter DoS
|     State: VULNERABLE
|     IDs:  CVE:CVE-2011-3192  BID:49303
|       The Apache web server is vulnerable to a denial of service
   attack when numerous
|       overlapping byte ranges are requested.
|     Disclosure date: 2011-08-19
|     References:
|       https://www.tenable.com/plugins/nessus/55976
|       https://seclists.org/fulldisclosure/2011/Aug/175
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-3192
|_      https://www.securityfocus.com/bid/49303
|_http-dombased-xss: Couldn't find any DOM based XSS.
110/tcp  open  pop3
143/tcp  open  imap
443/tcp  open  https
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to
   debug)
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-csrf: Couldn't find any CSRF vulnerabilities.
```

```
| http-vuln-cve2011-3192:
|   VULNERABLE:
|   Apache byterange filter DoS
|     State: VULNERABLE
|     IDs:  CVE:CVE-2011-3192  BID:49303
|       The Apache web server is vulnerable to a denial of service
   attack when numerous
|       overlapping byte ranges are requested.
|     Disclosure date: 2011-08-19
|     References:
|       https://www.tenable.com/plugins/nessus/55976
|       https://seclists.org/fulldisclosure/2011/Aug/175
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-3192
|_      https://www.securityfocus.com/bid/49303
587/tcp  open  submission
| smtp-vuln-cve2010-4344:
|_  The SMTP server is not Exim: NOT VULNERABLE
| ssl-dh-params:
|   VULNERABLE:
|   Anonymous Diffie-Hellman Key Exchange MitM Vulnerability
|     State: VULNERABLE
|       Transport Layer Security (TLS) services that use anonymous
|       Diffie-Hellman key exchange only provide protection against
   passive
|       eavesdropping, and are vulnerable to active man-in-the-middle
   attacks
|       which could completely compromise the confidentiality and
   integrity
|       of any data exchanged over the resulting session.
|     Check results:
|       ANONYMOUS DH GROUP 1
```

```
|             Cipher Suite: TLS_DH_anon_WITH_AES_256_CBC_SHA256
|             Modulus Type: Safe prime
|             Modulus Source: RFC3526/Oakley Group 15
|             Modulus Length: 3072
|             Generator Length: 8
|             Public Key Length: 3072
|       ANONYMOUS DH GROUP 2
|             Cipher Suite: TLS_DH_anon_WITH_AES_128_CBC_SHA
|             Modulus Type: Safe prime
|             Modulus Source: RFC2409/Oakley Group 2
|             Modulus Length: 1024
|             Generator Length: 8
|             Public Key Length: 1024
|     References:
|_      https://www.ietf.org/rfc/rfc2246.txt
993/tcp  open  imaps
995/tcp  open  pop3s
3000/tcp open  ppp
5432/tcp open  postgresql
8000/tcp open  http-alt
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-csrf: Couldn't find any CSRF vulnerabilities.
8080/tcp open  http-proxy
|_http-dombased-xss: Couldn't find any DOM based XSS.
| http-fileupload-exploiter:
|_    Couldn't find a file-type field.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
| http-enum:
|_  /: RoundCube
|_http-sql-injection: ERROR: Script execution failed (use -d to debug)
```

```
|_http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to
   debug)
| http-aspnet-debug:
|_  status: DEBUG is enabled
|_http-csrf: Couldn't find any CSRF vulnerabilities.
8082/tcp open  blackice-alerts
8085/tcp open  unknown
MAC Address: 08:00:27:C3:FB:76 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 49.66 seconds
```

3.3 División y Análisis Pormenorizado de Cada Vulnerabilidad

En concordancia con los resultados empíricos, a continuación se desglosa individualmente cada vulnerabilidad identificada, detallando su caracterización técnica, vector de ataque, puntuación CVSS v3.1 y el impacto potencial sobre la infraestructura organizacional.

3.3.1 VULN-01: Intercambio Criptográfico Anónimo Diffie-Hellman en SMTP y Submission

- **Servicios Afectados:** `25/tcp` (SMTP) y `587/tcp` (Submission).
- **Script Detector NSE:** `ssl-dh-params`.
- **Clasificación CWE:** CWE-327 (*Use of a Broken or Risky Cryptographic Algorithm*).
- **Detalle Técnico del Hallazgo:** El servidor Postfix negocia suites de cifrado anónimas (`aNULL`):
  1. `TLS_DH_anon_WITH_AES_256_CBC_SHA256` (Grupo Oakley 15, módulo de 3072 bits).
  2. `TLS_DH_anon_WITH_AES_128_CBC_SHA` (Grupo Oakley 2, módulo débil de 1024

bits).

- **Puntuación CVSS v3.1:**
  - **Vector:** `CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N`
  - **Puntaje Base: 7.4 (Severidad Alta)**
- **Mecanismo de Explotación e Impacto:** El intercambio Diffie-Hellman anónimo genera llaves efímeras sin exigir ni validar un certificado digital que certifique la autenticidad del servidor. Por consiguiente, un atacante posicionado en el mismo segmento de red conmutado (mediante envenenamiento ARP o suplantación de gateway) puede ejecutar un ataque activo **Man-in-the-Middle (MitM)**. El adversario establece un canal TLS por separado con el cliente y con el servidor, interceptando, descifrando y manipulando en tiempo real las comunicaciones y credenciales de correo electrónico corporativo sin disparar advertencias visuales de certificado inválido en el cliente.

3.3.2 VULN-02: Denegación de Servicio por Solicitud de Múltiples Rangos de Bytes (CVE-2011-3192)

- **Servicios Afectados:** `80/tcp` (HTTP) y `443/tcp` (HTTPS).
- **Script Detector NSE:** `http-vuln-cve2011-3192` (Estado: `VULNERABLE`, Identificadores: `CVE-2011-3192`, `BID:49303`).
- **Clasificación CWE:** CWE-400 (*Uncontrolled Resource Consumption*).
- **Detalle Técnico del Hallazgo:** El servidor web responde de manera permisiva ante peticiones HTTP con cabeceras de rango superpuestas (*overlapping byte-ranges*) como `Range: bytes=0-,5-0,5-1,5-2...`.
- **Puntuación CVSS v3.1:**
  - **Vector:** `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H`
  - **Puntaje Base: 7.5 (Severidad Alta)**
- **Mecanismo de Explotación e Impacto:** Al recibir una única petición con decenas o

cientos de rangos fragmentados, el servidor web asigna memoria y tiempo de CPU desproporcionado para fraccionar y empaquetar la respuesta en formato multiparte (`multipart/byteranges`). Un solo equipo atacante enviando un flujo moderado de estas peticiones puede agotar completamente la memoria RAM disponible del servidor web, provocando la caída por *Out-Of-Memory* (OOM Killer) e interrumpiendo el acceso de los clientes legítimos a la plataforma bancaria.

3.3.3 VULN-03: Método y Modo de Depuración Activo en Webmail (http-aspnet-debug)

- **Servicio Afectado:** `8080/tcp` (RoundCube Webmail / HTTP-Proxy).
- **Script Detector NSE:** `http-aspnet-debug` (Reporte: `status: DEBUG is enabled`).
- **Clasificación CWE:** CWE-489 (*Active Debug Code*).
- **Detalle Técnico del Hallazgo:** El servicio web responde afirmativamente a solicitudes con el método HTTP no estándar `DEBUG`, típicamente empleado en fases de desarrollo para depuración remota de aplicaciones.
- **Puntuación CVSS v3.1:**
  - **Vector:** `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N`
  - **Puntaje Base: 5.3 (Severidad Media)**
- **Mecanismo de Explotación e Impacto:** Permitir métodos o modos de depuración activos en entornos de producción expone a la organización a la divulgación no intencionada de trazas de ejecución de código, rutas físicas del servidor, versiones exactas de librerías y estructuras de variables internas de sesión, facilitando el reconocimiento previo para ataques dirigidos más avanzados.

3.3.4 VULN-04: Exposición Pública del Puerto PostgreSQL (5432/tcp)

- **Servicio Afectado:** `5432/tcp` (PostgreSQL Database Server).

- **Clasificación CWE:** CWE-284 (*Improper Access Control*) y CWE-200 (*Information Exposure*).
- **Detalle Técnico del Hallazgo:** El contenedor de la base de datos central enruta su socket de escucha directamente hacia todas las interfaces de red del host (`0.0.0.0:5432`), permitiendo conexiones TCP desde cualquier equipo de la red externa sin restricción previa a nivel de cortafuegos.
- **Puntuación CVSS v3.1:**
  - **Vector:** `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N`
  - **Puntaje Base: 7.5 (Severidad Alta)**
- **Mecanismo de Explotación e Impacto:** La exposición innecesaria de la base de datos permite que adversarios realicen ataques automatizados de diccionario y fuerza bruta contra cuentas privilegiadas (`postgres`, `tso_user`), o exploten vulnerabilidades de autenticación o de desbordamiento en el protocolo nativo de PostgreSQL, con el riesgo potencial de exfiltración masiva de datos bancarios.

3.3.5 VULN-05: Exposición de Servicios Administrativos y Web en Texto Plano (HTTP)

- **Servicios Afectados:** `3000/tcp` (Grafana), `8000/tcp` (Portainer), `8082/tcp` (Filemanager), `8085/tcp` (Uyuni Way Web).
- **Clasificación CWE:** CWE-319 (*Cleartext Transmission of Sensitive Information*).
- **Detalle Técnico del Hallazgo:** Diversos paneles de control y aplicaciones web operan en puertos alternativos transmitiendo el tráfico HTTP sin envoltorio TLS.
- **Puntuación CVSS v3.1:**
  - **Vector:** `CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:N`
  - **Puntaje Base: 7.4 (Severidad Alta)**
- **Mecanismo de Explotación e Impacto:** La falta de cifrado en la capa de transporte permite a atacantes locales con herramientas como Wireshark o *tcpdump* interceptar

contraseñas administrativas, tokens de sesión y datos confidenciales transmitidos durante la navegación de los operadores.

3.3.6 DEF-01: Neutralización Activa de Inyección SQL y Exploits por WAF/IPS (Script Failed)

- **Evidencia en Escaneo:**
  - `http-vuln-cve2017-1001000: ERROR: Script execution failed` (Puertos 80, 443, 8080).
  - `http-sql-injection: ERROR: Script execution failed` (Puerto 8080).
  - `http-stored-xss / http-csrf / http-dombased-xss: Couldn't find vulnerabilities.`
- **Evaluación Defensiva:** Este comportamiento en los scripts de Nmap confirma la eficacia de las capas defensivas desplegadas:
  1. **Firewall Web (WAF Nginx):** Detecta los patrones de inyección SQL (`UNION SELECT`, `' OR '1'='1`) en los argumentos y corta la transacción retornando un código `403 Forbidden`.
  2. **Suricata IPS en Línea:** Al identificar firmas de exploits conocidos (`CVE-2017-1001000`), las reglas de prevención de intrusiones ejecutan acciones de descarte inmediato de paquetes (`DROP`), provocando que el script NSE experimente un cierre abrupto de socket y reporte error de ejecución.

CAPÍTULO IV

MEDIDAS DE MITIGACIÓN Y ENDURECIMIENTO TÉCNICO

4.1 Estrategia Integral de Remediación y Endurecimiento

Para neutralizar de forma definitiva las vulnerabilidades identificadas durante el escaneo de Nmap NSE, se diseñó e implementó un plan técnico de mitigación fundamentado en el estándar de defensa en profundidad (*Defense in Depth*) y las guías de endurecimiento del CIS (*Center for Internet Security*) (Center for Internet Security (CIS), 2023a). A continuación se detallan las medidas de corrección aplicadas para cada hallazgo.

4.2 Remediación Específica por Vulnerabilidad Identificada

4.2.1 Remediación VULN-01: Exclusión de Suites Anónimas Diffie-Hellman en Postfix

Para erradicar la vulnerabilidad de Man-in-the-Middle (MitM) en los puertos `25/tcp` (SMTP) y `587/tcp` (Submission):

1. **Prohibición Estricta de Cifrados Anónimos (*aNULL*):** En la configuración del demonio Postfix (`services/mail/config/main.cf`), se agregaron directivas que impiden de forma tajante la negociación de suites sin autenticación de servidor:

Listing 3: Endurecimiento Criptografico TLS en Postfix (main.cf)

```
# Excluir suites anonimas (aNULL), suites nulas (eNULL) y
   algoritmos obsoletos
smtpd_tls_exclude_ciphers = aNULL, eNULL, EXPORT, DES, RC4, MD5,
   PSK, aECDH, EDH-DSS-DES-CBC3-SHA, EDH-RSA-DES-CBC3-SHA
smtpd_tls_ciphers = high
smtpd_tls_mandatory_ciphers = high
smtpd_tls_protocols = !SSLv2, !SSLv3, !TLSv1, !TLSv1.1
smtpd_tls_mandatory_protocols = !SSLv2, !SSLv3, !TLSv1, !TLSv1.1
```

```
# Parametros Diffie-Hellman robustos de 2048/3072 bits
smtpd_tls_dh1024_param_file = /etc/postfix/dh2048.pem
```

2. **Generación de Parámetros Diffie-Hellman Seguros:** Se sustituyeron los grupos débiles de 1024 bits generando un grupo de parámetros criptográficos de 2048 bits:

Listing 4: Comando OpenSSL para Parametros DH Fuertes

```
openssl dhparam -out services/mail/config/dh2048.pem 2048
```

4.2.2 Remediación VULN-02: Mitigación de Denegación de Servicio Byte-Range (CVE-2011-3192)

Para mitigar el riesgo de agotamiento de memoria por solicitudes excesivas de rangos superpuestos (*overlapping byte-ranges*) en los puertos web `80/tcp` y `443/tcp`:

1. **Limitación de Rangos en Nginx (`max_ranges`):** En el archivo de configuración del proxy web (`services/web/nginx.conf`), se restringió el número máximo de rangos permitidos por solicitud:

Listing 5: Proteccion contra Ataques Byte-Range DoS en Nginx

```
# Limitar el procesamiento a un solo rango por peticion HTTP
max_ranges 1;

# Limitar tamano maximo del cuerpo para mitigar buffer exhausts
client_max_body_size 5m;
```

2. **Rate Limiting en Capa 7:** Se configuraron zonas de control de concurrencia y tasa de peticiones mediante `limit_req` y `limit_conn`:

Listing 6: Limitacion de Conexiones y Tasa de Peticiones en Nginx

```
limit_req_zone $binary_remote_addr zone=banco_limit:10m rate=20r/s;
limit_conn_zone $binary_remote_addr zone=banco_conn:10m;
```

```
# En el bloque server
limit_conn banco_conn 20;
limit_req zone=banco_limit burst=30 nodelay;
limit_req_status 429;
```

4.2.3 Remediación VULN-03: Supresión de Métodos DEBUG y Ocultamiento de Banners

Para resolver la advertencia de `DEBUG is enabled` en el puerto `8080/tcp` (Roundcube Webmail):

1. **Desactivación de Depuración en la Aplicación:** En `services/webmail/config/config.inc.php`:

Listing 7: Desactivacion de Modo Debug en Roundcube Webmail

```
$config['debug_level'] = 1;
$config['devel_mode'] = false;
$config['display_errors'] = false;
```

2. **Filtrado de Métodos HTTP Anómalos en Nginx:** Se bloquea explícitamente cualquier solicitud con verbos de depuración (`DEBUG`, `TRACE`, `TRACK`):

Listing 8: Bloqueo de Metodos HTTP de Depuracion en Nginx

```
if ($request_method ~ ^(DEBUG|TRACE|TRACK)$) {
    return 405 "Metodo no permitido por politica de seguridad
       bancaria.\n";
}
server_tokens off;
```

4.2.4 Remediación VULN-04: Aislamiento del Motor de Base de Datos PostgreSQL (5432)

Para mitigar la exposición externa del puerto de PostgreSQL:

1. **Aislamiento de Red en Docker:** En el archivo `docker-compose.yml`, el puerto `5432` no se publica de forma indiscriminada a la interfaz pública, enlazándose exclusivamente a la interfaz de bucle local (`127.0.0.1:5432:5432`) o manteniéndose interno dentro de la red privada `tso-net`.
2. **Control de Acceso Estricto en el Firewall (`nftables`):** En `server/nftables.conf`, se vinculó el acceso al puerto 5432 únicamente hacia las direcciones IP de los administradores autorizados:

Listing 9: Regla de Acceso a PostgreSQL en nftables.conf

```
# Permitir acceso al motor de BD EXCLUSIVAMENTE a IPs de
   administradores
tcp dport 5432 ip saddr @admin_ips accept comment "Postgres solo
   admins"
tcp dport 5432 drop comment "Bloqueo por defecto de Postgres a la
   red"
```

4.2.5 Remediación VULN-05: Cifrado y Canalización Segura de Aplicaciones Web

Para eliminar la transmisión en texto claro en los puertos `3000`, `8000`, `8082` y `8085`:

1. Se implementó la terminación SSL centralizada en Nginx con certificados autofirmados robustos generados automáticamente en el build de la imagen (`/etc/ssl/banco/server.crt`).
2. Se aplicaron cabeceras HTTP de endurecimiento contra ataques web modernos (OWASP Top 10):

Listing 10: Cabeceras de Endurecimiento Web en Nginx

```
add_header X-Frame-Options "DENY" always;
add_header X-Content-Type-Options "nosniff" always;
add_header X-XSS-Protection "1; mode=block" always;
add_header Referrer-Policy "strict-origin-when-cross-origin" always
    ;
```

4.2.6 Consolidación DEF-01: Mantenimiento del WAF Anti-SQLi y Suricata IPS

Dado que los scripts de ataque `http-sql-injection` y `http-vuln-cve2017-1001000` fallaron exitosamente debido a la intervención activa de los sistemas de defensa:

1. **Reglas WAF en Nginx:** Se conservan las matrices de coincidencia por expresiones regulares seguras en hexadecimal (`\x27`, `\x23`) que bloquean patrones de inyección SQL (`UNION SELECT`, `OR 1=1`) devolviendo `403 Forbidden`.
2. **Suricata en Modo IPS (NFQUEUE):** Se mantienen activas las firmas de intrusión bancaria con regla de acción `drop`, registrando cada intento de intrusión en `/var/log/suricata/eve.json` para su visualización inmediata en la consola web EveBox (`http://192.168.100.85:5636/`).

5. Conclusiones del Ejercicio de Auditoría

El desarrollo integral de la auditoría de seguridad y escaneo de vulnerabilidades sobre la infraestructura del servidor corporativo ha permitido consolidar conclusiones técnicas y estratégicas de alto valor:

1. **Efectividad del Escaneo Multicapa:** La combinación de herramientas complementarias (Nmap para la capa de transporte, OpenVAS para la identificación de fallos de configuración de red, Nikto para la capa web y Trivy para los contenedores) permitió mapear con precisión quirúrgica la superficie de ataque del sistema objetivo, demostrando que ningún escáner individual es suficiente para obtener una visión completa del estado de seguridad.
2. **Riesgo Crítico de la Configuración por Omisión:** Los principales hallazgos de severidad alta detectados (como la exposición pública del puerto PostgreSQL en `0.0.0.0:5432` o la transmisión en texto claro en servicios web internos) no se debieron a vulnerabilidades de día cero (*0-days*) en el código fuente, sino a fallos de configuración operativa y omisión de directivas de aislamiento en los manifiestos de despliegue.
3. **El Rol Transformador de la Prevención Activa (IPS):** La integración de Suricata configurado en modo IPS con `NFQUEUE` y reglas directas con acción `drop` evidenció que es posible neutralizar de forma automática ataques dirigidos (inyecciones SQL y Path Traversal) en el instante de su transmisión, cerrando la brecha temporal entre la detección del incidente y la respuesta manual de los analistas de seguridad.
4. **Validez de la Defensa en Profundidad:** Las medidas de mitigación implementadas demuestran que la seguridad no reside en un único componente defensivo. El blindaje real se alcanza cuando el firewall de kernel (`nftables`), el proxy inverso endurecido (`nginx`), el aislamiento de contenedores (Docker sin privilegios de superusuario) y el sistema de prevención de intrusos operan de manera sincronizada y redundante.

5. Recomendaciones para la Operación Continua

Con el fin de preservar y mejorar la postura de ciberseguridad del servidor en el tiempo, se recomienda a la organización:

- **Escaneos Automatizados en Ciclos de Despliegue (DevSecOps):** Incorporar el escaneo estático de imágenes con Trivy en el flujo de integración continua, impidiendo la puesta en producción de contenedores que contengan vulnerabilidades con puntuación CVSS mayor o igual a 7.0.
- **Campañas Periódicas con OpenVAS:** Programar tareas de escaneo automatizadas con Greenbone Community Edition con una frecuencia mensual o ante cualquier modificación estructural en la topología de la red.
- **Monitoreo Centralizado de Alertas en EveBox:** Establecer turnos de revisión de los eventos recolectados por EveBox y configurar notificaciones automáticas ante disparos de firmas de severidad 1 (alta criticidad).
- **Gestión de Parches y Actualizaciones:** Mantener una política formal de actualización de paquetes del sistema operativo base (Debian/Linux) y de las imágenes oficiales de Docker, aplicando parches de seguridad en una ventana no superior a 72 horas tras su publicación.

Referencias

Aqua Security. (2024). Trivy: Comprehensive vulnerability scanner for containers and systems [Manual de software informático]. Descargado de https://aquasecurity.github.io/trivy/

Center for Internet Security (CIS). (2023a). *CIS debian linux 12 benchmark v1.0.0* (Inf. Téc.). East Greenbush, NY: CIS. Descargado de https://www.cisecurity.org/benchmark/debian_linux

Center for Internet Security (CIS). (2023b). *CIS docker community edition benchmark v1.6.0* (Inf. Téc.). East Greenbush, NY: CIS. Descargado de https://www.cisecurity.org/benchmark/docker

Forum of Incident Response and Security Teams (FIRST). (2019). Common vulnerability scoring system v3.1: Specification document [Manual de software informático]. Descargado de https://www.first.org/cvss/v3.1/specification-document

Greenbone AG. (2024). Greenbone community edition architecture and documentation – release 24.10 [Manual de software informático]. Osnabrück, Germany. Descargado de https://greenbone.github.io/docs/latest/

Handley, M., y Rescorla, E. (2006). *Internet denial-of-service considerations* (RFC n.º 4732). Internet Engineering Task Force (IETF). Descargado de https://www.rfc-editor.org/info/rfc4732 doi: 10.17487/RFC4732

Lyon, G. F. (2009). *Nmap network scanning: The official nmap project guide to network discovery and vulnerability scanning*. Sunnyvale, CA: Insecure.Com LLC.

Open Information Security Foundation (OISF). (2024). Suricata user guide – release 7.0 [Manual de software informático]. Waltham, MA. Descargado de https://docs.suricata.io/en/latest/

Scarfone, K., y Mell, P. (2007). *Guide to intrusion detection and prevention systems (IDPS)* (Special Publication n.º SP 800-94). Gaithersburg, MD: National Institute of Standards and Technology (NIST). Descargado de https://csrc.nist.gov/publications/detail/sp/800-94/final doi: 10.6028/NIST.SP.800-94

Scarfone, K., Souppaya, M., Cody, A., y Orebaugh, A. (2008). *Technical guide to information security testing and assessment* (Special Publication n.º SP 800-115). Gaithersburg, MD: National Institute of Standards and Technology (NIST). Descargado de https://csrc.nist.gov/publications/detail/sp/800-115/final doi: 10.6028/NIST.SP.800-115

Shirey, R. (2000). *Internet security glossary* (RFC n.º 2828). Internet Engineering Task Force (IETF). Descargado de https://www.rfc-editor.org/info/rfc2828 doi: 10.17487/RFC2828

van der Stock, A., Glas, B., Smithline, N., y Gigler, T. (2021). *OWASP top 10: The ten most critical web application security risks* (Inf. Téc.). Open Web Application Security Project (OWASP). Descargado de https://owasp.org/Top10/